

Authorization Layer

Draft architecture — Track C1: Safe Access to Patient Records | for team review

What this layer does

Authentication answers “who are you?”. This layer answers the next question: “now that we know who you are, what are you allowed to see?”. Every time a staff member opens a patient record, this layer checks the request before the record is returned. If the check fails, the record is not shown, and the attempt is logged either way.

The model: three factors, not one

A single “role” is too blunt on its own — a hospital has hundreds of nurses, and one nurse should not be able to open every patient in the building. Access is granted only when all three of these line up:

- **Role** — what kind of staff member this is (doctor, nurse, records clerk, lab technician, admin). Decides what *type* of data they can potentially see (e.g. lab staff see test results, not psychiatric notes).
- **Ward / department** — where this person currently works. A nurse on Ward 3 does not need to see patients on Ward 7.
- **Assignment** — whether this specific patient is currently under this specific staff member's care (admitted to their ward, on their patient list, or referred to them). This is the check that stops a staff member from browsing patients who simply happen to share their ward or role.

All three must pass. Role alone is not enough, and ward alone is not enough.

Default access by role

Role	Can normally see	Cannot see, by default
Doctor	Full record of assigned/admitted patients: history, notes, results, prescriptions	Patients not assigned to them or their ward
Nurse	Vitals, current medication, care notes for patients on their ward	Full diagnosis, history, other wards
Lab staff	Test orders and results they are processing	Clinical notes, patient history, unrelated departments
Records clerk	Demographic and administrative info (name, ID, billing, appointment)	Clinical diagnoses, prescriptions
Admin / IT	Account and system logs	Patient clinical content, unless explicitly escalated

This table is a starting point, not a final ruling — the exact fields per role should be reviewed with someone who knows real hospital workflows before we build against it.

How a request is decided

When someone tries to open a patient record, the system checks, in order:

- 1 Is this person authenticated (logged in, session valid)?
- 2 Does their **role** ever have access to this type of data?

- 3 Is this patient in their **ward/department**?
- 4 Are they specifically **assigned** to this patient right now?

If all four pass, access is granted and logged. If any fail, access is denied and the attempt is still logged — a denied request is itself useful data (it can be normal curiosity, or it can be the first sign of abuse).

Emergency override

A doctor in an emergency cannot be stopped by a login screen, so the system needs a “break glass” option: a way to open any patient's record immediately, bypassing the ward/assignment checks above. To keep this from becoming a loophole:

- The override still requires normal login (role and identity are never skipped).
- Using it requires a one-line reason typed in at the time (e.g. “code blue, Ward 4”) — not optional, not free text reviewed later only if there's a problem.
- Every override is flagged in the audit log differently from normal access, and is reviewed after the fact, not just recorded and forgotten.
- Overrides are visible to a supervisor in something close to real time, not buried in a log nobody reads.

What this layer hands to the audit/logging layer

For every access attempt (granted or denied), this layer should pass along: who, what patient record, what role/ward/assignment check they passed or failed on, whether it was a normal request or an emergency override, and when. The logging/tamper-evidence design itself is a separate piece — this is just the data it needs from us.

Open questions for the team

- How do we define “assigned” in our prototype data — admission record, referral, or something simpler we simulate?
- Do records clerks need read access to anything clinical at all, even redacted?
- What happens when a patient is transferred mid-shift — does the old ward's staff lose access immediately?
- Who counts as a “supervisor” for reviewing overrides, in our demo?